Penetration Test Report

Target Environment	404 Bank Internal Network (`404finance.local` , `10.1.253.129`)
Assessment Type	Internal Penetration Test (Assumed Breach / VPN Access)
Auditor	Rhys Prothero
Date	March 5, 2026

1. Executive Summary

404 Bank commissioned an internal penetration test to evaluate the security posture of their corporate infrastructure. The objective was to identify vulnerabilities and configuration flaws that an internal threat actor could leverage to compromise sensitive data or escalate privileges within the Active Directory (AD) environment.

Starting with zero knowledge beyond a VPN connection, the assessment team successfully achieved complete Domain Compromise (Domain Admin). The attack path exploited a combination of hardcoded credentials, weak password policies, excessive Active Directory delegated permissions (Broken Access Control), insecure credential storage, and a critical misconfiguration in Active Directory Certificate Services (AD CS).

The findings highlight a need for immediate remediation regarding identity management, the principle of least privilege within AD, and the securing of internal corporate applications.

2. Attack Narrative (Kill Chain)

1. **Initial Access:** Enumeration of the internal web server (`10.1.253.129`) revealed downloadable files. An executable (`CorpBankDialer.exe`) was reverse-engineered, exposing a hardcoded Base64 string that decoded to an MD5 hash. This hash was cracked (`Password123!!`) and successfully used in a password spraying attack against employee names scraped from the website, granting initial AD access via the `karl.hackermann` account.
2. **Internal Escalation & Lateral Movement:**
   - `karl.hackermann` possessed GenericWrite privileges over the `tom.reboot` user. This was exploited via targeted Kerberoasting to extract and crack `tom.reboot` 's password.
   - `tom.reboot` held ForceChangePassword rights over `robert.graef` , allowing the takeover of that account.
   - `robert.graef` had privileges to modify group memberships, which was abused to add the `jan.tresor` user to the Remote Desktop Users group.

3. **Privilege Escalation & Post-Exploitation:**
    - RDP access to `jan.tresor`'s machine revealed credentials for `daniel.hoffmann` left insecurely in the Recycle Bin.
    - WinRM access via `daniel.hoffmann` exposed an internal, non-routable web service (Port 5000). By resetting the `webadmin` password, access to this portal was achieved.
4. **Credential Harvesting:** A configuration backup ZIP downloaded from the portal was protected with a weak password, which was cracked using a custom wordlist built from the company's website. Inside, cleartext credentials for a service account (`svc.services`) were discovered.
5. **Domain Compromise (AD CS ESC4):** The disabled `svc.services` account was re-enabled utilizing permissions held by `robert.graef`. This service account possessed extensive control over an AD CS Certificate Template (`Vuln-ESC4`). The template was maliciously modified to an ESC1-vulnerable state, allowing the team to request an authentication certificate on behalf of the Domain Administrator. The resulting certificate was used to extract the Administrator NTLM hash via PKINIT, yielding total domain control.

3. Detailed Vulnerability Findings

3.1. Hardcoded Credentials in Executable Leading to Initial Access

Severity	**High**
CVSS v3.1 Score	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
OWASP Top 10	A07:2021-Identification and Authentication Failures / A02:2021-Cryptographic Failures
CWE	CWE-798: Use of Hard-coded Credentials / CWE-327: Use of a Broken or Risky Cryptographic Algorithm

Description

The `CorpBankDialer.exe` application hosted on the internal web server contained a hardcoded debugging artifact. Using the strings utility, a Base64 encoded string (`ZGQyZWYzNDUzMGRIN2U1YmVmMjJhMDVIN2U1ZGQxNzg=\n`) was discovered. Decoding this revealed an MD5 hash (`dd2ef34530de7e5bef22a05e7e5dd178`). MD5 is a deprecated hashing algorithm, and the hash was quickly cracked offline to reveal the plaintext password `Password123!!`. This password was valid for the Active Directory user `karl.hackermann`.

Remediation

- Remove all hardcoded credentials, debug tokens, and hashes from application source code and compiled binaries.
- Enforce strong password policies that prevent the use of easily guessable passwords like `Password123!!`.

3.2. Extensive Active Directory Delegated Permissions (BloodHound Paths)

Severity	**Critical**
CVSS v3.1 Score	8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
OWASP Top 10	A01:2021-Broken Access Control
CWE	CWE-269: Improper Privilege Management

Description

The Active Directory environment suffers from "permission bloat," creating a web of chained attack paths. Specifically:

1. `karl.hackermann` had GenericWrite over `tom.reboot` (allowing Targeted Kerberoasting).
2. `tom.reboot` had ForceChangePassword over `robert.graef`.
3. `robert.graef` had the ability to add users to Remote Desktop Users and manipulate Account Restrictions (enabling disabled accounts).
4. `daniel.hoffmann` had GenericWrite over `webadmin`.

This lack of the Principle of Least Privilege allowed a low-level compromised account to systematically leapfrog through the organization's user base.

Remediation

- Conduct a thorough review of Active Directory Access Control Lists (ACLs) using tools like BloodHound.
- Remove dangerous delegated permissions such as GenericWrite, GenericAll, ForceChangePassword, and WriteDacl from standard user accounts.
- Implement Tiered Administration to isolate highly privileged accounts from standard user workstations.

3.3. Insecure Storage of Sensitive Information (Recycle Bin & ZIP Files)

Severity	**Medium**
CVSS v3.1 Score	5.5 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)
OWASP Top 10	A04:2021-Insecure Design / A02:2021-Cryptographic Failures
CWE	CWE-312: Cleartext Storage of Sensitive Information

Description

During post-exploitation, sensitive data was discovered improperly secured in two instances:

1. Valid domain credentials (`daniel.hoffmann` / `RemoteAccess!2024`) were found residing in a deleted file within `jan.tresor` 's Recycle Bin.
2. An internal configuration backup (`config_backup.zip`) was secured with a weak password (`DontmessWithTexas`) that was easily cracked using terms scraped from the company website. The archive contained a `config.dat` file storing the `svc.services` domain credentials in cleartext.

Remediation

- Implement policies and provide training regarding the secure handling of credentials. Passwords should never be stored in text files.
- Utilize robust password managers or centralized secret management vaults (e.g., CyberArk, HashiCorp Vault).
- Ensure cryptographic archives (like ZIP files) utilize strong, complex passphrases resistant to dictionary attacks.

3.4. AD CS Certificate Template Misconfiguration (ESC4 / ESC1)

Severity	**Critical**
CVSS v3.1 Score	8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
OWASP Top 10	A01:2021-Broken Access Control
CWE	CWE-276: Incorrect Default Permissions

Description

The Active Directory Certificate Services (AD CS) infrastructure was found to have a severe misconfiguration on the `Vuln-ESC4` certificate template. The `svc.services` account possessed excessive permissions over this template, enabling an ESC4 attack.

The assessment team utilized Certipy to overwrite the template's configuration, enabling the "Enrollee Supplies Subject" flag and adding the "Client Authentication" EKU. This effectively turned the template into an ESC1 vulnerability. An authentication certificate was then requested specifying the Administrator Subject Alternative Name (SAN), allowing the extraction of the Domain Administrator's NTLM hash and resulting in total domain takeover.

Proof of Concept

```
# Modify template to vulnerable state (ESC4 -> ESC1)
certipy-ad template -u 'svc.services@404finance.local' -p 'S3rv1cePower2024!' -
template Vuln-ESC4 -dc-ip 10.1.253.129 -write-default-configuration

# Request certificate as Administrator (ESC1)
certipy-ad req -u 'svc.services@404finance.local' -p 'S3rvlcePower2024!' -template
Vuln-ESC4 -ca 404finance-DC-404-CA -dc-ip 10.1.253.129 -target dc-
404.404finance.local -upn administrator@404finance.local

# Authenticate and obtain NTLM hash
certipy-ad auth -pfx administrator.pfx -dc-ip 10.1.253.129
```

Remediation

- Review and restrict Access Control Lists (ACLs) on all Certificate Templates. Remove Write/Full Control permissions for standard users, service accounts, and the Authenticated Users group.
- If the `Vuln-ESC4` template is not actively required for business operations, unpublish it from the Certificate Authority.
- Ensure Manager Approval is required for any template that allows the requester to supply the Subject Name (SAN).

4. Conclusion and Strategic Recommendations

The assessment of the 404 Bank Internal Network revealed a highly permissive environment where a single initial foothold rapidly escalated to complete Domain Compromise. The underlying root cause of this exposure was not a single sophisticated zero-day, but rather a chain of systemic misconfigurations—specifically, hardcoded credentials, excessive Active Directory delegated permissions, and critical AD CS template vulnerabilities (ESC4/ESC1). To materially improve its security posture, 404 Bank must prioritize structural remediation efforts. Immediate focus should be placed on enforcing the Principle of Least Privilege across all accounts, securing or disabling vulnerable certificate templates, and eliminating cleartext credential storage. Implementing these foundational defense-in-depth strategies will significantly disrupt internal attack paths and drastically reduce the risk of future lateral movement by a malicious threat actor.